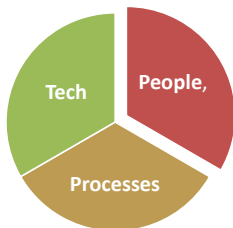


## 1.4 Organizational Structures, Roles & Responsibilities

- Governance requires clear **roles, mandates, and authority**
- COBIT outlines key attributes of effective structures
- Cross-functional alignment: **HR, Legal, Risk, Privacy, Audit**
- Security convergence = Integration of **InfoSec, IT, physical security**
- Goal: unified, end-to-end protection across **people, processes & tech**



In Section 1.4, we address a central principle of effective information security governance: the **clarity, structure, and integration** of roles and responsibilities. In any organization, governance cannot succeed without well-defined operating structures, clear ownership, and effective collaboration across departments. This section lays out what an effective organizational structure should look like—and what pitfalls to avoid.

The foundation of this discussion is **COBIT's framework**, which provides key attributes for building and evaluating organizational structures. According to COBIT, an effective structure:

Has a **formal mandate and documented responsibilities**

Includes **clear authority levels**, escalation paths, and delegation procedures

Maintains **interfaces with other stakeholders**, such as compliance, privacy, or HR

Has processes for **ongoing evaluation and improvement**

The **information security manager** must understand the enterprise's **org chart**, reporting relationships, and how decision-making flows—because the way security is embedded in these structures will significantly impact how strategy is implemented and maintained.

One challenge in many organizations is the existence of **siloed assurance**

**functions**—where departments like audit, privacy, HR, compliance, and legal all operate independently with little alignment. This fragmentation can lead to **gaps**, **redundancy**, or even **conflicting controls**. Security risks may fall through the cracks simply because **no single function is looking at the process end-to-end**.

That's why **security convergence** is gaining momentum. Convergence involves **integrating multiple security disciplines**, including:

Physical security

Information security

IT security

Risk management

Compliance

Privacy

Traditionally, these areas were managed in isolation. But as threats grow more complex and interconnected, organizations are rethinking this separation. One result is the rise of the **Chief Security Officer (CSO)**—a role that oversees **all facets of security**, combining what were once fragmented domains.

The **Sumitomo Mitsui Bank incident** in London illustrates this perfectly. Despite having robust IT controls, the attackers bypassed digital defenses through a **physical vulnerability**—by posing as janitors and planting keyloggers. It's a vivid example of how **security silos create blind spots**.

Convergence, however, is not just about combining departments. It's about **aligning security efforts with the business mission**—to enable consistent, predictable operations and safeguard stakeholder value. It must span **people, processes, and technology**, and support the enterprise in **preventing, detecting, responding to, and recovering from threats** of any kind.

### 1.4.1 Roles and Responsibilities in Security Governance

- Clear role and responsibility definitions are critical
- Everyone has InfoSec responsibilities must be communicated regularly
- Roles = Job function | Responsibilities = Tasks assigned
- Use RACI Matrix:
  - o **Responsible** does the work
  - o **Accountable** owns the outcome
  - o **Consulted** gives input
  - o **Informed** kept up to date
- One "A" per task; multiple "R"s allowed



Section 1.4.1 brings our attention to one of the most practical components of information security governance: the **definition and communication of roles and responsibilities**. Without clarity on **who does what**, even the most well-structured governance frameworks can fall apart due to confusion, inaction, or overlapping efforts.

Let's start with the basics:

A **role** is a position or function someone holds—usually tied to their job title or department.

A **responsibility** is a specific task or duty that person is expected to carry out. Every single person in an enterprise has **some level of information security responsibility**, whether they realize it or not. For this reason, it's critical for security leaders to **clearly define, document, and communicate** responsibilities **regularly**—not just during onboarding or audits.

To assign and manage these duties efficiently, organizations often use the **RACI Matrix**—a widely adopted tool for clarifying role involvement across multiple activities or processes. RACI stands for:

**R – Responsible:** The individual(s) who actually do the work to complete the task. There can be more than one person with an R.

**A – Accountable:** The one person ultimately answerable for the task. There

should be only **one A** per task or decision.

**C – Consulted:** Subject matter experts or stakeholders whose input is needed. This is a two-way communication.

**I – Informed:** Those who need to be updated on progress or results. This is typically one-way communication.

RACI helps ensure there is **no ambiguity, no gaps, and no overlaps** in critical activities. For example, if an incident response process is being mapped out, RACI can identify who initiates the response (R), who signs off on the resolution (A), who provides input (C), and who is informed of the final outcome (I).

Importantly, while the **Accountable (A)** role may delegate execution to others, they still **retain full accountability** for results. This ensures there is always someone who owns the outcome—and can be held accountable if it fails.

RACI can be used to document:

Roles in policy development

Risk management activities

Audit response processes

Incident response workflows

Compliance and regulatory efforts

Ultimately, the RACI Matrix supports **efficiency, transparency, and governance maturity**. It's also useful during audits, board reviews, or regulatory inspections, as it demonstrates that **roles and responsibilities are systematically managed**.

## Skills in Defining Roles & Responsibilities

- Skills = training, experience, and expertise
- Roles must align with available skills and competencies
- Training can address gaps; short-term needs may require external help
- Formal agreements should reflect security responsibilities
- Skills mapping critical during hiring and resource planning



As we complete Section 1.4.1, it's important to remember that simply defining roles and assigning responsibilities isn't enough. The **skills** needed to fulfill those responsibilities must also be considered carefully—especially when creating or applying a **RACI matrix** within your information security governance program.

**Skills** refer to the **training, knowledge, experience, and proficiencies** held by individuals in specific job functions. These aren't just technical qualifications—they also include communication skills, risk assessment expertise, compliance knowledge, and project management experience, depending on the role.

A RACI chart becomes significantly more effective when paired with a **skills assessment**. There's no value in assigning someone as "Responsible" for a task if they don't have the necessary competencies to carry it out effectively. This could lead to poor execution, compliance failures, or critical delays in security operations.

Understanding the **capabilities of your workforce** is essential. Information security managers should routinely assess whether existing staff possess the skills required to:

Implement new controls  
Lead risk assessments

Respond to incidents

Engage with auditors or regulators

Maintain or improve security systems

If a **skills gap is identified**, it can be addressed in one of two ways:

**Internal training and development**—This is often the best long-term solution and can support team retention and organizational growth.

**External resources or consultants**—In many cases, this is more **cost-effective** for short-term or highly specialized tasks. For example, if the organization needs to conduct a PCI-DSS compliance assessment or implement zero trust architecture, bringing in an expert may be more efficient than training internal staff from scratch.

Furthermore, once specific responsibilities are assigned to individuals, they should be **formally documented in employment agreements** or job descriptions. This gives clarity to both the individual and the organization, and it provides a **legal and procedural basis** for performance evaluation, accountability, and—when necessary—disciplinary action.

These agreements also serve a purpose during **recruitment and screening**. HR and hiring managers must understand the **security-related responsibilities tied to each position**, so they can evaluate whether candidates have the right background to fulfill those expectations.

## Role of the Board of Directors in Security Governance

- The board must understand risks to information assets
- Should receive risk assessment and BIA results regularly
- Has **legal, ethical & fiduciary** duty to oversee InfoSec
- Failure to exercise **due care** may void insurance coverage
- Sarbanes-Oxley links InfoSec to financial integrity
- Board involvement impacts governance ratings & investor confidence



As we close out Domain 1 on Information Security Governance, it's essential to understand the role of the **Board of Directors** in shaping and overseeing an organization's information security strategy. This is not just good practice—it's a **regulatory, legal, and fiduciary obligation**.

Board members are ultimately **responsible for safeguarding enterprise value**, and in today's information-driven economy, that means being aware of the **risks to key information assets**. They don't need to understand every technical detail, but they must have enough context to provide strategic oversight and **validate that appropriate protections are in place**.

This starts with visibility. The board should be provided with **high-level results of risk assessments and business impact analyses (BIAs)**. These insights help them understand the **criticality of information systems**, the **consequences of failure**, and whether current security measures align with the enterprise's risk appetite.

Importantly, the board also plays a role in **enforcing security culture**. Security expectations must be clearly defined and enforced at **every level of the enterprise**, starting from the top. Penalties for noncompliance, if defined and enforced from the board level downward, send a strong message that security is a shared, non-negotiable responsibility.

The board's **oversight role** also includes **regular review of key metrics** and **alignment with evolving risks**. Cyber-risk is not static, and reporting mechanisms should evolve as threats and business strategies change. Organizations like the **National Association of Corporate Directors (NACD)** have formally recognized this need, emphasizing modernized, adaptive cyber-risk oversight.

There are **significant liability concerns** for directors who fail to exercise due care. In many jurisdictions, boards are protected by **director and officer (D&O) liability insurance**. However, this protection is contingent on the board demonstrating **good faith efforts** to fulfill their governance responsibilities. Ignoring information security can be seen as negligence and may **void insurance protections**.

The **Sarbanes-Oxley Act (SOX)** further ties the board into information security responsibilities—specifically through the requirement for an **audit committee**, often composed of board members, to oversee internal controls. Since many of those controls are **technical or security-related**, the **information security manager must maintain open, regular communication** with this committee. Beyond regulatory requirements, investors and ratings agencies now consider **governance maturity**, including security oversight, in their assessments. Poor governance or major security lapses can negatively impact **corporate ratings, investor confidence, and market value**.

## Role of Senior Management in Security Governance

- Security success depends on active leadership from senior management
- Senior leaders ensure resources, policies, and infrastructure are in place
- Must balance security, compliance, performance, and cost
- Key role in mediating between IT and Security teams
- Support from the top drives accountability and culture



In the governance framework, **senior management** plays a crucial bridging role between the **Board of Directors** and the **operational execution teams**, particularly those responsible for IT and security. The board sets strategic direction, but it is **senior management that makes it real** by allocating resources, enforcing policy, and promoting organizational alignment. As with any other business-critical initiative—be it mergers, digital transformation, or compliance—**information security cannot succeed without sustained support and leadership from senior management**. This support goes beyond issuing mandates or approving budgets. It requires **ongoing engagement, clear communication, and decision-making authority** to help navigate conflicts and competing priorities.

A key responsibility of senior management is to **ensure that the necessary organizational functions and infrastructure exist** to support the information security program. This means making sure:

The **security function has adequate funding and personnel**

Policies and procedures are not only developed but also **enforced**

The **risk appetite** is clearly understood and communicated across departments

Regulatory requirements are integrated into business operations

One of the recurring challenges in many organizations is the **disconnect**

**between IT and security.** IT is often driven by performance, innovation, and efficiency—goals that prioritize speed, user experience, and system availability. Security, in contrast, is driven by risk management, control implementation, and regulatory compliance. These **different priorities can create tension.** For example, security might delay a cloud rollout due to data privacy risks, while IT is under pressure to meet delivery deadlines.

In such cases, it is senior management's job to **mediate between the two**, provide clarity on organizational priorities, and enforce **alignment between risk tolerance and business objectives.** Without this intervention, IT and security may operate at odds, resulting in friction, delays, or even security failures. Senior leadership also sets the **tone for enterprise-wide accountability.** When employees see that top management takes security seriously—by attending awareness sessions, asking for metrics, enforcing compliance—they're more likely to follow suit. Conversely, lack of executive involvement signals that security is optional, reducing the program's effectiveness.

## Role of Business Process Owners (BPOs)

- BPOs ensure InfoSec aligns with business objectives
- Active participation leads to risk-aware processes
- Their input improves strategy relevance & effectiveness
- Enable acceptable levels of assurance and impact



In the context of CISM and enterprise risk management, BPOs are the **bridge between the security function and business execution**. They are the subject matter experts for specific business functions—such as finance, HR, operations, customer support—and **own the processes that generate, handle, and rely on information**. Because of this, their involvement in information security planning and implementation is not optional; it is **essential**.

One of the main objectives of an information security program is to **achieve alignment between security controls and business objectives**. That alignment is not automatic. Security professionals cannot fully understand every detail of every business process. Without the insights of BPOs, controls may be implemented that are either too weak to mitigate actual risks—or too rigid, hampering productivity and agility.

When BPOs are engaged, they bring deep operational context. They can:

**Identify process-level risks**

Explain the **business impact of different threat scenarios**

Provide **realistic expectations** for downtime or recovery time

Help prioritize security investments based on actual business priorities

This collaboration helps shape a **risk-informed strategy** that delivers

**predictable levels of assurance** and **minimizes the cost of security**. When

security is right-sized and targeted, it's more effective and less intrusive. This is where **cost-effectiveness** enters the picture—a major focus for the CISM exam. The cooperation of BPOs also ensures **ownership of outcomes**. When a business process owner has helped define the controls and understands why they exist, they're more likely to:

- Promote compliance among their teams

- Integrate controls into day-to-day operations

- Support audits and incident response when needed

Another key point is **impact tolerance**. Only the BPO can define what constitutes an “acceptable level of impact” for their process in the face of a security incident. For example, losing a CRM system for four hours might be acceptable for some departments—but unacceptable for others. Without BPO input, InfoSec teams may over- or underestimate tolerance levels, leading to misaligned recovery objectives.

From a CISM exam standpoint, expect questions that test your ability to identify **stakeholder responsibilities** or align controls with business goals. Often, the correct answer involves **consulting or collaborating with BPOs** during risk assessments, control selection, or incident planning.

## Chief Information Security Officer (CISO)

- CISO ensures InfoSec aligns with enterprise objectives
- Legal and governance accountability often reside at C-level
- Reports to **CEO**, board, or high-level executive in mature orgs
- Must justify resources & build risk-based business cases
- Works closely with **CPO/DPO** on privacy and data protection



The **Chief Information Security Officer (CISO)** plays a pivotal role in the governance and success of an enterprise's information security strategy. Regardless of title or formality, **every organization has someone filling the CISO role**, whether that's officially the CISO, or another executive such as the CIO, CFO, CSO, or even the CEO.

Why is this role so central? Because information security governance is not just about protecting systems—it's about **aligning security with business objectives, managing risk, enabling compliance, and ensuring resilience**. The CISO must function at a strategic level, integrating InfoSec into enterprise planning and execution.

Legally and operationally, the **responsibility for security extends up the hierarchy**, ultimately to the board of directors and senior leadership. If governance structures are not properly established, senior leaders may **underestimate their liability exposure**. This can lead to inadequate resourcing, misalignment with business goals, and a lack of visibility into emerging threats. In mature organizations, the CISO reports **directly to the CEO, the board, or a governance committee**, reflecting the increasing importance of security to enterprise viability. However, in many companies, the InfoSec manager may still report to the CIO or IT leadership and lack formal authority—this variation is a

reality reflected in the CISM exam.

A key function of the CISO is to **build and justify the security program's budget**. This is not merely about requesting more funding. It's about **demonstrating how investment in security reduces risk, ensures compliance, and supports business continuity**. The CISO must articulate risk in business terms that resonate with other executives—using tools like risk quantification, threat modeling, and incident impact analysis.

Importantly, the CISO must collaborate closely with the **Chief Privacy Officer (CPO) or Data Privacy Officer (DPO)**. The overlap between information security and privacy is expanding rapidly—especially under global regulatory regimes like GDPR, HIPAA, and others. A successful CISO understands the **shared accountability** for safeguarding personal and sensitive data and must align InfoSec practices with privacy frameworks.

## Risk Management Roles & Responsibilities

- Risk management supports **security governance** objectives
- Roles must be defined at all **organizational levels**
- Board and **senior management** hold ultimate **accountability**
- Consistent framework prevents **gaps** and duplication
- **Integration** enables clear, enterprise-wide **risk posture**



Risk management is not just a support function for information security — it is at the **core of the security governance mandate**. Understanding how risk is distributed and managed across an organization is essential to achieving alignment between business objectives and security outcomes.

Let's begin with a fundamental principle: **Managing risk at an acceptable cost** is a primary goal of any information security program. This means **finding a balance** between the protection of assets and the cost of implementing that protection. It also means acknowledging that **not all risk can or should be eliminated**—some must be accepted, transferred, or mitigated to a tolerable level.

From a governance standpoint, the **board of directors and senior management bear ultimate responsibility** for risk management. Their roles include setting the **risk appetite**, ensuring **regulatory and compliance obligations are met**, and making sure that security strategies align with enterprise goals. However, this is not a top-down-only model—**every role in the enterprise** has responsibilities when it comes to managing risk.

A key concept here is **integration**. All risk management activities must function **under a consistent set of rules, policies, and goals**. Without this integration, departments may:

Duplicate efforts,  
Misalign their controls,  
Or leave **critical security gaps**.

One team might overprotect an asset, while another team is unknowingly exposing a vulnerability. That's where centralized and well-coordinated governance—often through an enterprise risk management (ERM) framework—becomes essential.

In many modern enterprises, the **information security manager (often the CISO)** plays a leading role in organizing these risk activities. They may report directly to the **CEO**, a **Chief Risk Officer**, or another high-level executive, underscoring the critical role of security in managing enterprise risk.

The **NIST SP 800-30 Rev. 1** framework—often referenced globally—outlines key roles in risk assessments:

**Senior leaders** who define the mission context and accept risk,

**Risk executives** who provide consistent guidance across all assessments,

**Information owners** who understand business impact,

And **system owners** or administrators who implement controls.

The CISM exam expects candidates to understand not just the **definitions of these roles**, but how to ensure they operate **in harmony**. For example, risk assessments must be shared, communicated, and updated collaboratively—not siloed.

Another practical takeaway is the **importance of aligning InfoSec and risk management with organizational priorities**. If security is trying to reduce risk in a vacuum—without understanding what matters to business leaders—it's likely to misallocate resources or frustrate operations.

In summary, effective risk management in information security requires:

**Defined responsibilities at every level,**

**Integrated risk processes** across departments,

And a strong **governance model** that connects all stakeholders with a shared objective: keeping the enterprise secure, compliant, and resilient.